

Manual 43 — ISO/IEC 27017 & 27018 Cloud Security and Privacy Controlled Implementation

****Controlled baseline:**** ISO/IEC 27017:2026 Edition 2 and ISO/IEC 27018:2025 Edition 3, with ISO/IEC 27001/27002 and applicable privacy law treated as separate related layers.

****Copyright boundary:**** this manual contains project-authored summaries and implementation guidance only; it does not reproduce protected ISO control text and is not an authorized ISO translation.

****Release rule:**** reverify edition status immediately before candidate freeze.

Chapter 01 — Source and copyright boundary

Maintain authoritative edition metadata, purchased-standard access controls where applicable, project-authored summaries, copyright restrictions, citation records, and release-time version checks.

Chapter 02 — Scope and standard relationships

Define the scope of ISO/IEC 27017 cloud security guidance and ISO/IEC 27018 public-cloud PII processing guidance, and document their relationship to ISO/IEC 27001, 27002, 27701, contracts, and law.

Chapter 03 — Cloud service models

Classify IaaS, PaaS, SaaS and related managed-service models, documenting which responsibilities remain with provider, customer, tenant administrators, integrators, and subprocessors.

Chapter 04 — Customer and provider accountability

Assign accountable owners for security, privacy, service management, architecture, incident response, vendor oversight, evidence, and contractual obligations on both sides of the service relationship.

Chapter 05 — Shared responsibility

Create service-specific responsibility matrices that map control ownership, configuration duties, evidence sources, dependencies, exceptions, escalation paths, and verification frequency.

Chapter 06 — Information-security governance

Integrate cloud risks into policy, risk assessment, control design, change management, assurance, management review, corrective action, and continual improvement.

Chapter 07 — Asset and configuration governance

Inventory cloud accounts, subscriptions, projects, workloads, data stores, images, secrets, configurations, regions, dependencies, and owners; maintain approved secure baselines and drift monitoring.

Chapter 08 — Identity and access

Govern identity federation, account lifecycle, authentication, authorization, service identities, conditional access, segregation, periodic review, and evidence of revocation.

Chapter 09 — Privileged cloud administration

Protect administrative roles through least privilege, strong authentication, privileged access workflows, just-in-time elevation, logging, break-glass controls, review, and separation of duties.

Chapter 10 — Virtualized and shared environments

Assess isolation, multi-tenancy, hypervisor or container boundaries, shared services, noisy-neighbor risks, metadata services, tenant separation, and provider assurance evidence.

Chapter 11 — Administrative operations

Control provider and customer operational procedures, maintenance, support access, automation, consoles, emergency changes, remote administration, and operational evidence.

Chapter 12 — Network and cloud architecture

Design segmentation, ingress/egress control, private connectivity, gateways, service endpoints, DNS, firewalls, load balancers, exposure management, and architecture review.

Chapter 13 — Logging and monitoring

Define required cloud audit logs, workload telemetry, administrative events, security alerts, retention, time synchronization, integrity, centralized analysis, and investigation access.

Chapter 14 — Cryptography and key management

Define encryption requirements, key ownership, provider-managed versus customer-managed keys, rotation, backup, access, revocation, HSM use, secrets handling, and evidence.

Chapter 15 — Vulnerability and configuration management

Manage images, hosts, containers, services, dependencies, patches, configuration findings, remediation SLAs, exceptions, compensating controls, and continuous posture monitoring.

Chapter 16 — Incident management

Define provider/customer incident roles, detection, triage, evidence access, communications, containment, legal/privacy assessment, notification support, lessons learned, and corrective action.

Chapter 17 — Resilience and availability

Set resilience objectives, region/zone architecture, backups, recovery, capacity, dependency mapping, service continuity, testing, provider outage procedures, and evidence of recovery exercises.

Chapter 18 — Portability and interoperability

Plan export formats, interfaces, dependencies, identity migration, data extraction, configuration transfer, lock-in risks, testing, exit criteria, and contractual support.

Chapter 19 — Secure deletion and return

Define return, deletion, cryptographic erasure, residual copies, backups, media handling, tenant termination, provider attestations, exceptions, and verification evidence.

Chapter 20 — Supplier and subprocessor governance

Inventory providers and subprocessors, assess security/privacy capability, contract requirements, location, changes, incidents, audit rights, assurance reports, remediation, and termination.

Chapter 21 — Public-cloud PII processor scope

Determine when the relevant service acts in a public-cloud PII processor role and document instructions, responsibilities, data categories, processing purposes, and legal overlays without overstating ISO guidance as law.

Chapter 22 — Customer instructions and purpose limits

Document authorized processing instructions, permitted purposes, prohibited secondary use, change control, support access, deletion, retention, and evidence of provider adherence.

Chapter 23 — Disclosure and transparency

Maintain transparency about provider identity, subprocessors, locations, security/privacy capabilities, disclosure processes, service changes, and material risks relevant to customers.

Chapter 24 — Breach support

Define provider obligations to detect and communicate relevant events, preserve evidence, support customer risk assessment and notification, coordinate subprocessors, and document remediation.

Chapter 25 — Data location and transfer considerations

Track storage, replication, support access, remote administration, subprocessors, transfer mechanisms, localization requirements, contractual safeguards, and jurisdiction-specific risk decisions.

Chapter 26 — Contractual controls

Translate cloud security/privacy responsibilities into service agreements, DPAs, security schedules, SLAs, incident clauses, audit rights, subprocessor terms, deletion, exit, and evidence commitments.

Chapter 27 — Evidence and auditability

Define evidence for responsibility assignments, configurations, access, logs, incidents, supplier controls, deletion, resilience, privacy instructions, testing, and corrective actions; preserve traceability.

Chapter 28 — Risk treatment

Assess cloud-specific threats, shared-control failures, provider dependencies, concentration, misconfiguration, data exposure, privacy risks, resilience, and exit constraints; track treatment and acceptance.

Chapter 29 — Crosswalks to 27001, 27002, and 27701

Use project-authored crosswalks as implementation aids only. Document scope assumptions, non-equivalence, edition differences, and evidence mappings without reproducing protected standard text.

Chapter 30 — Metrics and assurance limitations

Track cloud posture findings, privileged access, incident support, supplier issues, recovery tests, deletion evidence, privacy exceptions, remediation aging, and assurance coverage while stating evidence limitations.

Chapter 31 — Localization, provenance, and copyright control

Freeze EN/es-419/pt-BR project editions, preserve the non-authorized-translation notice, bind DOCX/PDF candidates to SHA-256, and retain source-version, structure, parity, accessibility, render, workflow-security, and staging evidence.

Chapter 32 — Edition-status reverification and release governance

Immediately before publication, reverify ISO/IEC 27017 and 27018 edition status and related-standard dependencies. Confirm predecessor Manual 42 publication, exact artifact identity, clean staged-head QA, copyright boundary, and registry reconciliation before release.